

1. Executive Summary

Subject: PCI-DSS SAQ-A Assessment – Threads & Trends Boutique **Date:** January 13, 2026

Threads & Trends utilizes a fully outsourced payment model (Shopify + Stripe). The merchant *does not* store, process, or transmit Cardholder Data (CHD) directly. This assessment validates the security of the redirect/iframe mechanisms and the integrity of the web storefront to prevent supply-chain attacks such as digital skimming.

2. Scope & Asset Inventory

- **Scope:** The e-commerce website threadsandtrends.com and administrative workstations.
- **Assets:**
 - **Data:** Customer PII (Names, Addresses), Session Tokens. **(No CHD in scope).**
 - **Systems:** Shopify Admin Panel, DNS Registrar, 3rd Party Marketing Plugins.
 - **People:** Site Administrator, Marketing Contractors.

3. Threat Actors & Motivations

- **Magecart/E-Skimmers:** Motivated by injecting code to steal credit cards during input.
- **Competitors/Fraudsters:** Denial of Service (Availability) or Inventory Hoarding.
- **Phishers:** Targeting Admin credentials to hijack the store.

4. Compliance Obligations

- **PCI-DSS v4.0 (SAQ-A):**
 - Applicable to card-not-present merchants that outsource all card functions.
 - **Key Requirements:** Secure passwords, patch management, restricting physical access to paper records (if any), and managing third-party service providers (TPSPs).

5. Risk Assessment Matrix

Risk ID	Risk Description	Threat Source	Vulnerability	L	I	Score	Level
P-01	Supply Chain Injection (Skimming)	Advanced Criminal	Vulnerable 3rd Party Plugin	3	5	15	High
P-02	Admin Account Takeover	Phisher	Weak Password / No MFA	4	5	20	Critical
P-03	Payment Vendor Failure	TPSP	Vendor Outage	2	4	8	Low

6. Recommended Controls

- **Technical (P-01):** Implement Content Security Policy (CSP) headers to restrict where scripts can load from; conduct quarterly external vulnerability scans (ASV).
- **Technical (P-02):** Enforce MFA (Multi-Factor Authentication) for all access to the Shopify Admin panel; disable "staff" accounts for inactive contractors.
- **Administrative (P-03):** Maintain a "Vendor Risk Management" log ensuring Stripe and Shopify maintain their own PCI-DSS Level 1 compliance attestation (AOC).

7. Business Impact Narrative

"As an online-only retailer, website availability is synonymous with revenue. However, the greater risk is fraud; if a digital skimmer is injected into our checkout page, customers will suffer credit card theft. Under PCI rules, the merchant is liable for fines and forensic investigation costs, which could bankrupt the business and result in permanent revocation of card processing privileges."